تقرير اختبار اختراق تطبيق ويب

OWASP Juice Shop

IDOR · Negative Quantity · SQL Injection

المُعِدّة	رهف البركاتي
تاريخ الاختبار	أكتوبر 2026
الهدف	OWASP Juice Shop — http://localhost:3000
نوع الاختبار	صندوق رمادي (Gray Box) بحسابين مستخدم عاديين
الأدوات	Burp Suite Community 2026.10.1، متصفح Chrome

نُفِّذ هذا الاختبار على نسخة محلية من OWASP Juice Shop، وهو تطبيق مصمَّم عمدًا بثغرات لأغراض التعلّم. لم يُختبر أي نظام حقيقي، وجميع الحسابات والبيانات الظاهرة في الأدلة تجريبية.

الملخص التنفيذي

أُثبتت ثلاث ثغرات بالدليل، أخطرها حقن SQL في صفحة الدخول الذي يمكّن أي شخص — دون حساب — من الدخول بصلاحيات المدير. واختُبرت فرضية رابعة (XSS في حقل البحث) ولم تُثبت بالأدلة المتاحة.

#	الثغرة	نقطة الاختبار	الخطورة
1	تجاوز المصادقة عبر حقن SQL	`POST /rest/user/login`	حرجة
2	الوصول لسلة مستخدم آخر (IDOR)	`GET /rest/basket/:id`	عالية
3	قبول كمية سالبة ينتج إجماليًا سالبًا	`PUT /api/BasketItems/:id`	عالية
—	XSS في حقل البحث	حقل البحث	غير مثبتة

منهجية الاختبار

اتُّبعت لكل حالة الخطوات نفسها: تحديد **السلوك المتوقع**، ثم **الملاحظة** التي أثارت الشك، ثم صياغة **فرضية** قابلة للاختبار، ثم **الاختبار** بتغيير متغير واحد، وأخيرًا **الدليل** الذي يثبت الفرضية أو ينفيها.

منهجية تقييم الخطورة

تُقيَّم كل ثغرة على محورين منفصلين، ثم يُحدَّد التقييم النهائي من الجمع بينهما:

المحور	ما يقيسه
سهولة الاستغلال	هل يحتاج المهاجم حسابًا؟ هل يتطلب مهارة أو أدوات خاصة؟ هل الشرط متوفر دائمًا؟
حجم الأثر	ما البيانات أو الصلاحيات المتأثرة؟ هل الأثر على مستخدم واحد أم على النظام كله؟ هل هناك خسارة مالية؟

الثغرة 1

حرجة

تجاوز المصادقة عبر حقن SQL

نقطة الاختبار	`POST /rest/user/login`
التصنيف	OWASP A03:2021 – Injection · CWE-89 · CWE-287

حقل البريد الإلكتروني يُدمج مباشرة في استعلام قاعدة البيانات، فتسمح حمولة بسيطة بالدخول إلى حساب المدير دون كلمة مرور.

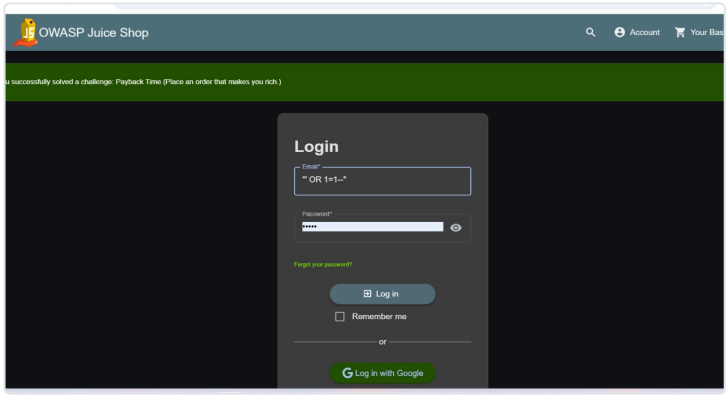
1. **السلوك المتوقع:** يُقبل الدخول فقط عند تطابق البريد مع كلمة المرور الصحيحة.
2. **الملاحظة:** إدخال علامة اقتباس مفردة ' في حقل البريد أثّر على سلوك الاستعلام.
3. **الفرضية:** إن كان الاستعلام مبنيًا بدمج نصي، فإن شرطًا دائم الصحة سيعطّل فحص كلمة المرور ويُرجع أول مستخدم في الجدول (المدير).
4. **الاختبار:** إدخال الحمولة التالية في حقل البريد مع كلمة مرور عشوائية: `' OR 1=1--`

الدليل

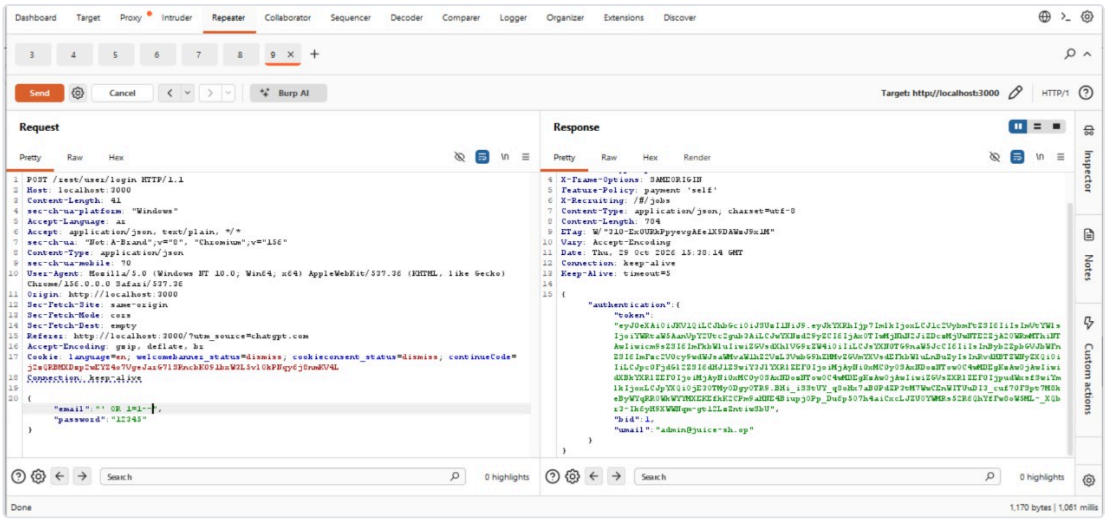
```
POST /rest/user/login HTTP/1.1
{"email":"' OR 1=1--","password":"<random>"}

HTTP/1.1 200 OK
{"authentication":{"token":"eyJ0eXAi…","bid":1,"umail":"admin@juice-sh.op"}}
```

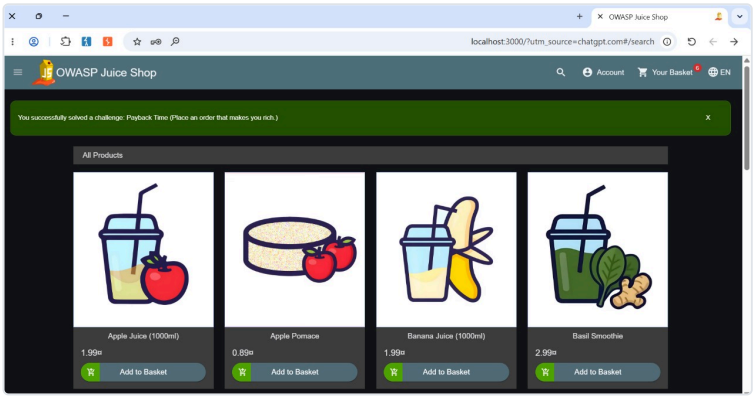
أعاد الخادم 200 OK مع توكن جلسة صالح مرتبط بحساب المدير.



شكل 1: الحمولة في حقل البريد الإلكتروني



شكل 2: الطلب والاستجابة في Burp — توكن لحساب admin@juice-sh.op



شكل 3: جلسة نشطة بصلاحيات المدير بعد تجاوز المصادقة

تقييم الخطورة

سهولة الاستغلال	حجم الأثر	التقييم النهائي
عالية جدًا	**حرج**	**حرجة**
عن بُعد، دون أي حساب، بحمولة معروفة من سطر واحد.	سيطرة على أعلى حساب صلاحيةً، ما يهدد سرية النظام وسلامته بالكامل.	أعلى سهولة مع أعلى أثر.

لم يشمل الاختبار استخراج بيانات إضافية من قاعدة البيانات، لذا لا يُدّعى ذلك كنتيجة مؤكدة.

التوصية

- استخدام استعلامات مُعلَّمة (Parameterized Queries) بدل دمج مدخلات المستخدم في نص الاستعلام.
- التحقق من صيغة البريد الإلكتروني على الخادم قبل استخدامه.
- إظهار رسائل خطأ عامة لا تكشف تفاصيل قاعدة البيانات.
- تقييد صلاحيات حساب قاعدة البيانات بالحد الأدنى اللازم.

الثغرة 2

عالية

الوصول لسلة مستخدم آخر (IDOR)

نقطة الاختبار	`GET /rest/basket/:id`
التصنيف	OWASP A01:2021 – Broken Access Control · CWE-639

الخادم لا يتحقق من ملكية السلة، فيستطيع أي مستخدم مسجَّل قراءة سلة غيره بتغيير رقمها في الرابط.

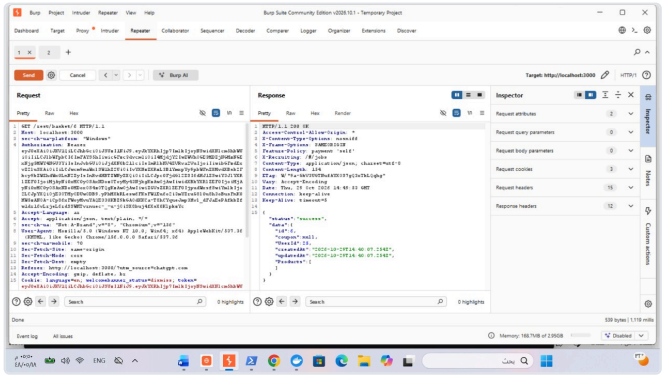
1. **السلوك المتوقع:** يرى كل مستخدم سلته فقط.
2. **الملاحظة:** معرّف السلة رقمي متسلسل في المسار (`/rest/basket/6`). هذا وحده لا يثبت ثغرة، لكنه يستدعي الاختبار.
3. **الفرضية:** قد يُرجع الخادم سلة أي معرّف دون التحقق من أنها تخص صاحب التوكن.
4. **الاختبار:** تغيير المعرّف من 6 إلى 7 مع إبقاء توكن الحساب A دون تعديل، ومقارنة الرد ببيانات الحساب B.

الدليل

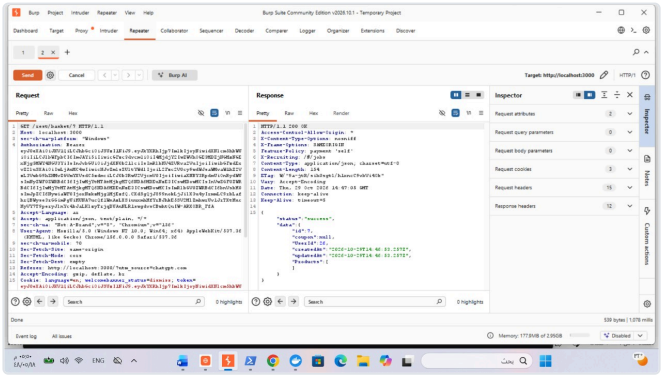
الطلب	التوكن المستخدم	الرد	النتيجة
`GET /rest/basket/6`	الحساب A	`UserId = 25`	طبيعي
`GET /rest/basket/7`	الحساب B	`UserId = 26`	خط الأساس
`GET /rest/basket/7`	**الحساب A**	**`UserId = 26`**	**ثغرة مثبتة**

```
# Authorization: Bearer <token A>
GET /rest/basket/7 HTTP/1.1

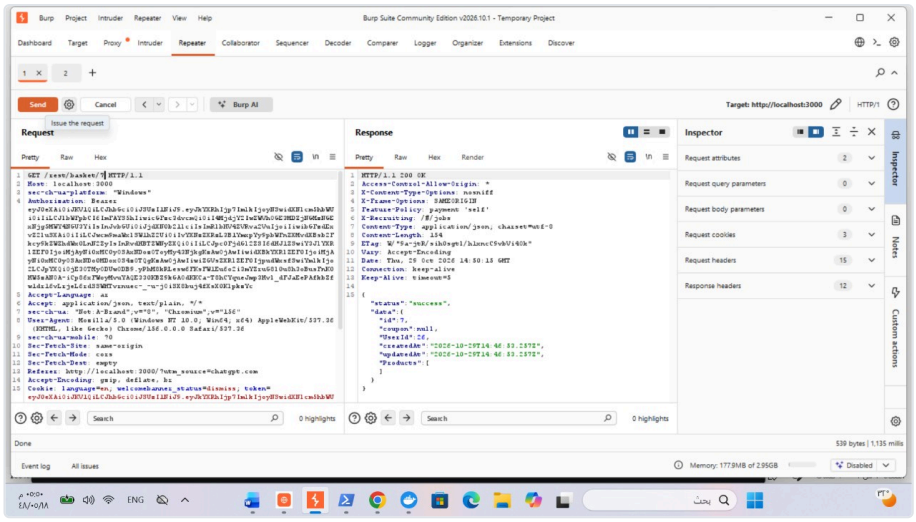
HTTP/1.1 200 OK
{"status":"success","data":{"id":7,"coupon":null,"UserId":26,"Products":[]}}
```



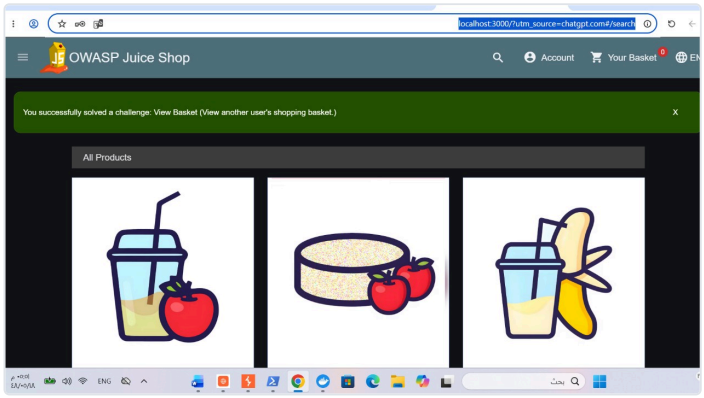
شكل 4: الحساب A يطلب سلته (bid=6) — الرد UserId=25



شكل 5: خط الأساس — سلة الحساب B (bid=7) بتوكنه — UserId=26



شكل 6: الاستغلال — توكن الحساب A يُرجع سلة الحساب B (UserId=26)



شكل 7: تأكيد التطبيق لحل التحدي "View Basket"

تقييم الخطورة

سهولة الاستغلال	حجم الأثر	التقييم النهائي
عالية	**متوسط**	**عالية**
يكفي أي حساب عادي وتغيير رقم متسلسل قابل للتخمين.	قراءة فقط لمحتوى السلال، لكن لجميع المستخدمين أفقيًا.	سهولة عالية مع أثر يشمل كل المستخدمين.

لم يُختبر تعديل سلال الآخرين أو طلباتهم؛ ويُنصح باختباره لأن نمط ضعف التحقق من الملكية قد يتكرر في عمليات أخرى.

التوصية

- التحقق على الخادم في كل طلب من أن السلة المطلوبة تخص المستخدم صاحب التوكن.
- الأفضل جلب سلة المستخدم من هويته في الجلسة بدل قبول معرّفها من العميل.
- رفض الطلب غير المصرّح به بـ 403 Forbidden أو 404 Not Found دون كشف أي بيانات.

الثغرة 3

قبول كمية سالبة ينتج إجماليًا سالبًا

عالية

نقطة الاختبار	`PUT /api/BasketItems/:id`
التصنيف	OWASP A04:2021 – Insecure Design · CWE-20 · CWE-840

الخادم لا يتحقق من إشارة الكمية، فيقبل كمية سالبة ويُكمل الطلب بإجمالي سالب، أي أن المتجر يدين للعميل بدل العكس.

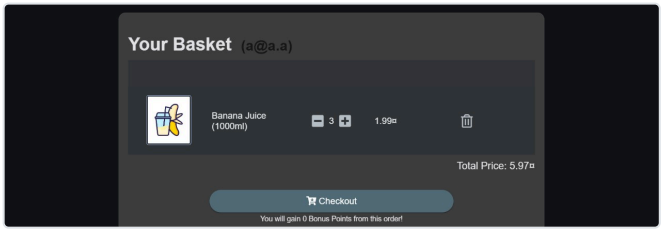
1. **السلوك المتوقع:** الكمية عدد صحيح موجب (1 فأكثر)، والإجمالي لا يقل عن صفر.
2. **الملاحظة:** الكمية تُرسل من العميل في جسم الطلب (الحقل `quantity`) وتُقبل كما هي، وهي مدخل يتحكم في الحساب المالي.
3. **الفرضية:** إن لم يتحقق الخادم من الإشارة، فستُقبل قيمة سالبة وتنتج إجماليًا سالبًا.
4. **الاختبار:** اعتراض طلب تحديث الكمية في Burp وتغييرها من 3 إلى سالب 3، ثم إتمام الشراء.

الدليل

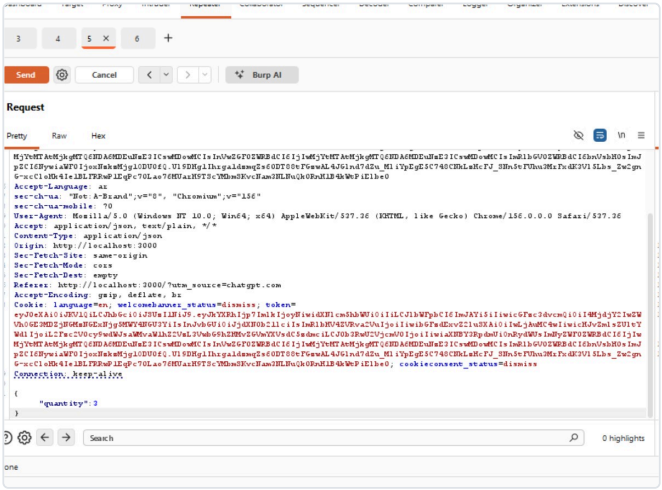
```
PUT /api/BasketItems/{id} HTTP/1.1
{"quantity":-3}

HTTP/1.1 200 OK
{"status":"success","data":{…,"quantity":-3,…}}
```

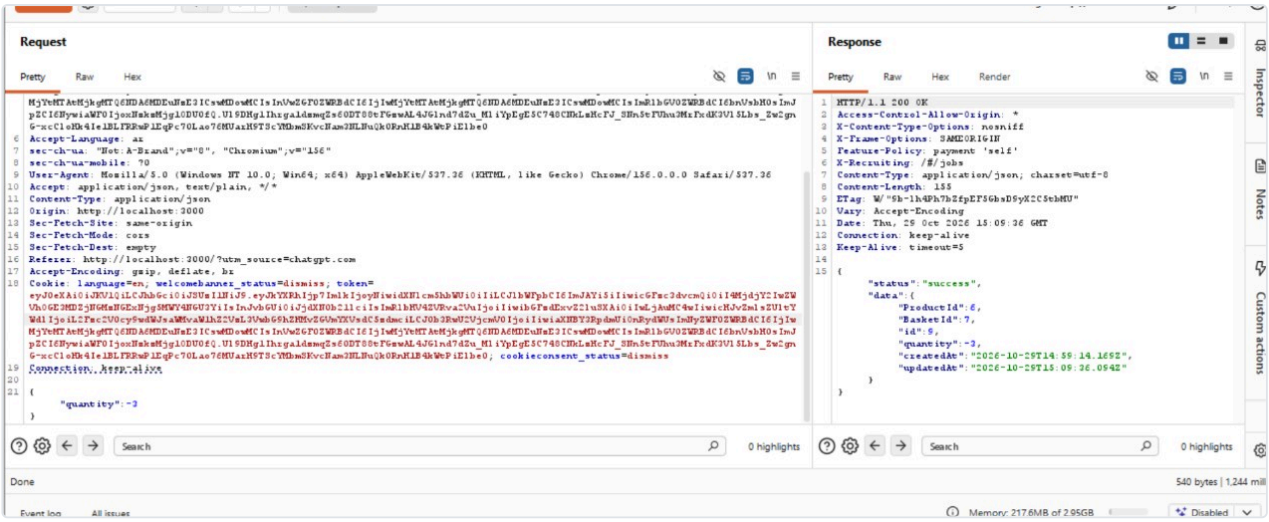
	الكمية	إجمالي المنتجات	الإجمالي النهائي
قبل التلاعب	3	5.97	5.97
بعد التلاعب	**-3**	**-5.97**	**-4.98**



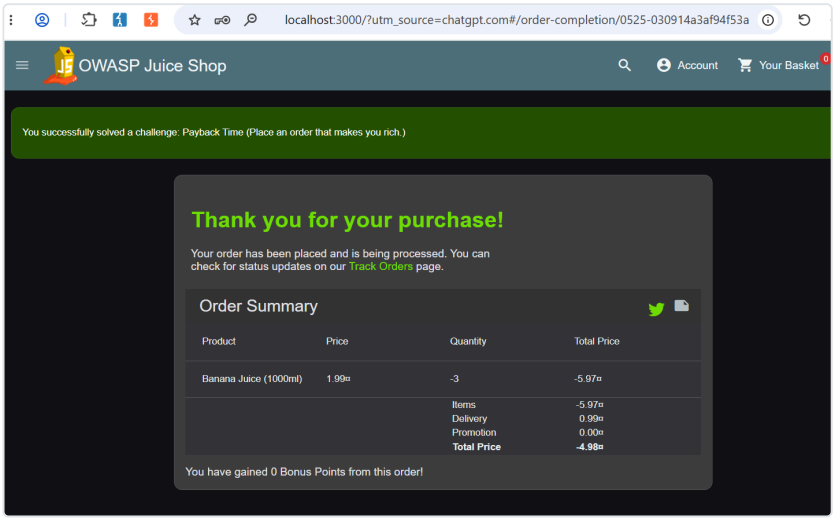
شكل 8: السلة بالحالة الطبيعية (كمية 3، إجمالي 5.97)



شكل 9: الطلب الطبيعي لتحديث الكمية



شكل 10: الطلب بكمية 3- — الخادم يقبله ويخزّن القيمة



شكل 11: ملخص الطلب بإجمالي 4.98- وتأكيد تحدي "Payback Time"

تقييم الخطورة

سهولة الاستغلال	حجم الأثر	التقييم النهائي
عالية	**عالٍ**	**عالية**
أي مستخدم لديه حساب، بتعديل قيمة واحدة في الطلب.	خسارة مالية مباشرة وكسر لمنطق الفوترة، لكنه محصور في الطلبات ولا يمس بيانات المستخدمين.	ضرر مالي مباشر وسهل التكرار.

التوصية

- التحقق من الكمية على الخادم: عدد صحيح موجب ضمن حد أقصى معقول، ورفض أي قيمة أقل من 1.
- إعادة حساب الإجمالي على الخادم ومنع إنشاء أي طلب بإجمالي سالب.

فرضية اختُبرت ولم يثبت وجود ثغرة

احتمال وجود XSS في حقل البحث

غير مثبتة

الفرضية

قد يسمح حقل البحث بإدخال كود JavaScript وتنفيذه داخل المتصفح، مما قد يؤدي إلى ثغرة Cross-Site Scripting (XSS).

ما الذي اختبرته؟

أدخلت قيمة اختبار تحتوي على كود JavaScript في حقل البحث، ثم راقبت سلوك التطبيق والنتيجة التي ظهرت في الصفحة.

النتيجة

عمل البحث، لكن لم يظهر تنبيه JavaScript (Alert)، ولم أتمكن من إثبات تنفيذ الكود داخل المتصفح.

لماذا استُبعدت الفرضية؟

استُبعدت هذه الحالة من قائمة الثغرات المؤكدة؛ لأن الاختبار لم يُظهر دليلًا واضحًا على تنفيذ JavaScript أو وجود أثر أمني فعلي، وعمل البحث وحده لا يثبت وجود ثغرة XSS.

> لذلك سُجّلت الفرضية على أنها **غير مثبتة**، لا على أنها **آمنة بشكل قاطع**.